



АКТ РОЗШИРЕНОГО АУДИТУ «КОРПУС» v4.0.0

Технічний · науковий · кібербезпековий · операційний assurance dossier

Дата	1 серпня 2026
Об'єкт	KORPUS_INFRA_HARDENED_v4.0.0
Release evidence	main@a6056c5 · tag v4.0.0
Scope	Static code/config + local executable assurance + standards crosswalk
Фінальний статус	FAIL — production; PASS_WITH_CAVEATS — controlled pilot на відкритих даних

Контрольне твердження

Неможливо довести «100% усіх можливих вразливостей» нетривіальної системи. Акт фіксує 100% проблем, виявлених у визначеному audit score, і явно відокремлює неперевірені production-зони.

1. Виконавчий висновок

НІ — система не готова до production або роботи з обмеженим військовим корпусом. Вона є сильним research/engineering baseline і може використовуватися для подальшої розробки та контрольованого pilot лише на відкритих або синтетичних даних.

Показник	Результат	Статус
Production readiness	29.2/100	EXTRAPOLATED
Знайдено findings	99	ANCHORED до цього audit scope
P0 blockers	30	Launch forbidden
Локальний suite	124 PASS / 1 PostgreSQL-only SKIP	ANCHORED, але не production evidence

Причина низької production-оцінки: найсильніші частини об'єкта — локальні інваріанти, hash/audit design і executable tests. Найслабші — реальні дані, production identity, parser isolation, calibration provenance, live infrastructure, SRE, supply-chain attestations, independent verification та формальна authorization.

2. Score, метод і доказова дисципліна

- Об'єкт: source ZIP v4.0.0, committed reports, API/PWA/Compose/GitLab CI, migrations, scripts, tests та local assurance artifacts.
- Методи: static architecture/security review; повторний local execution; метааналіз тестової решітки; source metrics; threat modeling; standards crosswalk; null-attack на claims.
- Стани findings: VERIFIED_DEFECT — безпосередньо видно у коді/конфігурації/вимірі; UNVERIFIED_BLOCKER — production-доказ обов'язковий, але відсутній; CONDITIONAL_RISK — залежить від deployment/data class, однак має бути закритий до запуску.
- Числа мають provenance tag. Production readiness — EXTRAPOLATED weighted gate, не емпірична ймовірність безпеки.

3. Повторно підтверджений стан

Evidence	Значення	Що доводить	Чого не доводить
Pytest	124 PASS, 1 PostgreSQL-only SKIP	Заявлені локальні contracts	Live PostgreSQL/Docker/IdP/S3
Coverage	86.72% statements; 64.78% branches; 82.34% combined	Виконання частини code paths	Semantic correctness/absence of unknown bugs
Adversarial eval	30/30; UNVALIDATED_TEST_FIXTURE	Відповідність synthetic scenarios	Real corpus generalization
Mutation	14/14 killed	Сила 14 вибраних predicates	Повний mutation space
Scale	5 000 SQLite spans; p95≈2.42 ms	Локальний FTS path	Production p95/p99/concurrency/pgvector
Operational gate	PASS; production_authorized=false	Композицію local reports	Формальну готовність до експлуатації

4. Weighted production-readiness gate

Формула: $\Sigma(\text{weight} \times \text{domain_score}/10)$. Ваги сумарно 100%. Це керована експертна EXTRAPOLATION; невідоме не отримує позитивного бала.

Домен	Вага	Бал /10	Підстава
Architecture & maintainability	10%	6.5	Core boundaries are thoughtful; god objects/config complexity remain.
Functional/local correctness	8%	7.5	124 PASS + mutation/adversarial evidence, but mostly local/synthetic.

Scientific evaluation & calibration	10%	3.0	30 synthetic cases; no real blinded corpus or human gold set.
Identity & authorization	10%	3.0	OIDC verifier exists; UI and entitlement/PDP/high-assurance controls absent.
Corpus/data governance	10%	1.0	Real corpus, rights, classification and signed release absent.
Application/AI security	10%	3.0	Some leakage/injection gates; no sandbox, fuzzing, independent red-team.
Infrastructure/deployment	10%	2.5	Strong local design; no live production topology evidence.
SRE/DR/observability	8%	2.0	Runbooks/design exist; no SLO, HA, live restore, on-call or durable telemetry.
Supply-chain assurance	8%	2.5	SBOM/scans jobs exist; mutable tags, no hash lock/provenance/signing.
Privacy/legal/data lifecycle	6%	1.0	Rights, retention, deletion, PII and legal-hold controls unproven.
Independent verification	5%	0.0	No external assessment.
Operational authorization	5%	0.0	Explicitly false.

Підсумок: 29.2/100 — FAIL.

5. Launch blockers — стислий контрольний список

1. **GOV-001 · Немає формальної production authorization** — UNVERIFIED_BLOCKER. PASS: Підписаний authorization decision, scope, residual-risk register і expiry date.
2. **GOV-002 · Немає use-case-specific AI risk profile** — UNVERIFIED_BLOCKER. PASS: Кожен risk має owner, metric, control, evidence і review cadence.
3. **GOV-003 · Немає затвердженої класифікації та правил обробки даних** — UNVERIFIED_BLOCKER. PASS: 100% corpus objects мають owner, class, rights, retention, releasability і access policy.
4. **GOV-004 · Немає незалежного TEVV, pentest і red-team** — UNVERIFIED_BLOCKER. PASS: Незалежний звіт без відкритих P0/P1 та з повторною перевіркою remediation.
5. **GOV-005 · Немає офіційної моделі предметної відповідальності** — UNVERIFIED_BLOCKER. PASS: Кожне approval криптографічно прив'язане до уповноваженої ролі та score.
6. **GOV-006 · Права на індексацію, OCR, цитування й передачу документів не доведені** — CONDITIONAL_RISK. PASS: Для кожного джерела зафіксовані дозволені операції та заборони.
7. **IAM-001 · Небезпечний secure-by-default: dev auth дає restricted admin** — VERIFIED_DEFECT. PASS: Будь-який non-test start без OIDC/explicit local override завершується exit!=0.
8. **IAM-002 · Production web-клієнт не реалізує OIDC** — VERIFIED_DEFECT. PASS: End-to-end OIDC login/logout/expiry/revocation проходить у staging.
9. **IAM-003 · Привілеї напряму довіряються довільним OIDC claims** — VERIFIED_DEFECT. PASS: Підроблені/невідомі claims не підвищують доступ; mapping version audited.
10. **IAM-004 · Модель доступу не виражає need-to-know/compartments** — CONDITIONAL_RISK. PASS: Набір cross-compartment noninterference tests PASS на DB і API.
11. **ING-001 · Upload повністю буферизується в RAM** — VERIFIED_DEFECT. PASS: Peak RSS bounded під N concurrent max-size uploads.
12. **ING-002 · OCR/парсинг синхронні в API request** — VERIFIED_DEFECT. PASS: Crash/restart test завершує або безпечно повторює job без дублювання.
13. **ING-003 · Немає malware scan/CDR до parser execution** — VERIFIED_DEFECT. PASS: EICAR/malformed/polyglot fixtures блокуються до extraction.

14. **ING-004 · Untrusted PDF парситься в API trust domain** — VERIFIED_DEFECT. PASS: Compromise simulation не бачить DB/IdP/S3 credentials і не має egress.
15. **ING-005 · Aggregate OCR budget фактично не обмежений** — VERIFIED_DEFECT. PASS: Worst-case file завершується в заданий budget і очищає temp artifacts.
16. **RAG-001 · Evaluation dataset є synthetic fixture, не production evidence** — VERIFIED_DEFECT. PASS: Blind holdout, human adjudication, versioned dataset, confidence intervals.
17. **RAG-002 · Calibration profile не криптографічно зв'язаний з фактичним dataset artifact** — VERIFIED_DEFECT. PASS: Runtime перевіряє signed bundle та точний dataset/code digest перед calibrated mode.
18. **RAG-003 · Немає human gold standard та inter-annotator agreement** — UNVERIFIED_BLOCKER. PASS: IAA threshold predefined; ambiguous cases excluded/separately scored.
19. **INF-001 · Docker/Compose runtime не був фактично виконаний у середовищі аудиту** — UNVERIFIED_BLOCKER. PASS: Full stack starts from zero and passes E2E under non-root roles.
20. **INF-002 · docker-compose.yml є local topology, не production deployment** — VERIFIED_DEFECT. PASS: Production config passes policy-as-code and has no dev settings/plain HTTP.
21. **INF-003 · Немає production TLS ingress і service identity** — UNVERIFIED_BLOCKER. PASS: All external and sensitive internal paths cryptographically authenticated.
22. **INF-004 · Немає HA/failover/PITR topology** — UNVERIFIED_BLOCKER. PASS: Failover drill meets defined RTO/RPO with no authorization bypass.
23. **INF-005 · Backup/restore не доведено на live production-like PostgreSQL** — UNVERIFIED_BLOCKER. PASS: Independent restore evidence with measured RTO/RPO and checksum reconciliation.
24. **INF-006 · Немає production secret manager/KMS/HSM і rotation evidence** — UNVERIFIED_BLOCKER. PASS: No long-lived static secrets in images/files; rotation without downtime tested.
25. **SRE-001 · Немає SLO/SLI/error-budget contract** — UNVERIFIED_BLOCKER. PASS: Approved SLO document and burn-rate alerts validated.
26. **SRE-002 · Немає on-call ownership та incident exercises** — UNVERIFIED_BLOCKER. PASS: Timed exercises meet detection/containment/recovery targets.
27. **SUP-001 · Container/CI images pinned tags, not immutable digests** — VERIFIED_DEFECT. PASS: All release inputs are digest-pinned and provenance records exact digests.
28. **SUP-002 · Python lock files не містять hashes** — VERIFIED_DEFECT. PASS: Offline/reproducible install succeeds only for approved hashes.
29. **SUP-003 · Немає signed build provenance і artifact signing** — UNVERIFIED_BLOCKER. PASS: Deployment admission rejects unsigned/unexpected provenance.
30. **DATA-001 · Немає enforceable retention/deletion/legal-hold policy** — UNVERIFIED_BLOCKER. PASS: Automated tests prove retain/delete/hold/declassify behavior.

6. Обов'язкові протоколи закриття

PR-01 • Scope, threat model and data classification

Мета	Freeze deployment context, actors, assets, trust boundaries, attack surfaces and data classes.
Метод	STRIDE + LINDDUN + MITRE ATLAS mapping; misuse/abuse cases; data-flow diagrams.
Інструменти	Threat model tool, DFD, classification registry, architecture decision records.
PASS predicate	All P0 attack paths have owner/control/test; no UNKNOWN trust boundary.

PR-02 • Identity, entitlement and database noninterference

Мета	Prove identity authenticity, least privilege and cross-compartment isolation.
Метод	OIDC conformance, token abuse tests, entitlement mapping, RLS adversarial SQL, timing tests.
Інструменти	IdP staging, OPA/Cedar, PostgreSQL, Schemathesis/pytest, pgaudit.
PASS predicate	Wrong/replayed/low-assurance token denied; arbitrary SQL cannot widen claims; zero leakage.

PR-03 • Untrusted document quarantine and extraction

Мета	Make parser compromise non-catastrophic and ingestion resumable.
Метод	Streaming quarantine, AV/CDR, sandbox, resource budgets, job state machine, fault injection.
Інструменти	ClamAV/YARA, CDR, gVisor/Firecracker, queue/workflow engine, fuzzers.
PASS predicate	Malicious/malformed files never reach trusted runtime; crash resumes idempotently.

PR-04 • Corpus authority, versioning and reviewer governance

Мета	Prove document authenticity, currency, ownership and approval authority.
Метод	Registry reconciliation, signature checks, bitemporal/supersession tests, dual review, signed release.
Інструменти	PKI/PAdES, corpus registry, workflow, cosign/in-toto.
PASS predicate	Every retrieved span belongs to signed approved release valid as-of query date.

PR-05 • Retrieval, attribution and abstention calibration

Мета	Measure retrieval and claim support on realistic blinded corpus.
Метод	Stratified gold set, train/dev/test split, nDCG/MRR/Recall, ALCE/RAGChecker metrics, conformal/selective risk, bootstrap CIs.
Інструменти	Annotation platform, evaluation harness, NLI verifier, statistical notebooks.
PASS predicate	Pre-registered thresholds pass on untouched holdout and worst critical strata.

PR-06 • AI/RAG adversarial security

Мета	Attack injection, poisoning, leakage, evasion, denial of service and excessive trust.
Метод	MITRE ATLAS/OWASP scenarios, poisoned corpus canary, Unicode/obfuscation fuzz, egress monitoring.
Інструменти	Dioptra/custom harness, DLP, red-team tooling, fault injector.
PASS predicate	No unauthorized disclosure/action; detected poisoning rolls back before general release.

PR-07 • Secure software supply chain

Мета	Prove exact source→build→artifact lineage and dependency integrity.
Метод	Digest pinning, hash locks, isolated builds, SBOM, SAST/SCA, signed provenance, two-party review.
Інструменти	GitLab protected branches, cosign/in-toto, Syft/Trivy, Semgrep, pip-audit.
PASS predicate	Deploy gate verifies SLSA provenance/signature/SBOM; no unaccepted high/critical issue.

PR-08 • Production topology, load and chaos

Мета	Prove service survives expected load and dependency failures.
Метод	Staging parity, mixed load/soak, saturation, chaos, canary, rollback, DB/object failover.
Інструменти	k6/Locust, Toxiproxy/Chaos Mesh, OpenTelemetry, pg tools.
PASS predicate	SLOs met; overload sheds safely; failover/rollback preserve data and authorization.

PR-09 • Backup, restore and cryptographic recovery

Мета	Prove recovery, not merely backup creation.
Метод	3-2-1/WORM, timed restore, key rotation/revocation, PITR, integrity and access checks.
Інструменти	KMS/HSM, backup platform, isolated restore environment.
PASS predicate	Measured RPO/RTO pass; restored system passes RLS, corpus and audit verification.

PR-10 • Production Readiness Review and authorization

Мета	Convert evidence into accountable launch decision.
Метод	Independent PRR, runbooks/on-call, incident game day, residual-risk acceptance, staged launch.
Інструменти	Google SRE PRR checklist, NIST AI RMF/SSDF dossier, sign-off workflow.
PASS predicate	All P0 closed; P1 explicitly accepted/mitigated; signed time-bounded authorization issued.

7. Послідовність робіт

Хвиля	Зміст	Finding groups	Exit gate
Wave 0 — launch freeze	Заборонити production/restricted data; зафіксувати scope, risk owner, data classification, threat model.	GOV-001...006, DATA-001	Scope signed; production frozen
Wave 1 — identity and secure	Закрити dev-admin default,	IAM-001...008	Identity noninterference PASS

defaults	production OIDC UI, entitlement PDP, MFA/replay, compartments, DB isolation.		
Wave 2 — ingestion isolation	Streaming quarantine, AV/CDR, parser sandbox, durable jobs, aggregate budgets, source authenticity.	ING-001...012	Malicious-file sandbox PASS
Wave 3 — corpus/evidence science	Real gold set, signed calibration bundle, attribution/contradiction, Ukrainian morphology, tables/numbers, drift.	RAG-001...020	Blind holdout/calibration PASS
Wave 4 — production platform	Prod IaC, TLS/mTLS, KMS, HA/PITR, live restore, egress policy, durable telemetry.	INF/SRE/AUD/DATA	Live SLO/DR/HA PASS
Wave 5 — supply chain and independent assurance	Digest/hash pinning, SLSA, signing, full scanners/fuzz, two-party controls, pentest/red-team.	SUP/COD/GOV-004	Signed supply chain + independent report
Wave 6 — PRR and staged launch	SLO, on-call, game days, canary open-data pilot, external acceptance, time-bounded authorization.	PR-08...PR-10	Signed authorization

8. Повний реєстр findings

Усього: 99. P0=30, P1=56, P2=13. Повний машинний backlog додано окремо у CSV/JSON.

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
GOV-001	P0 UNVERIFIED_BLOCKER	Немає формальної production authorization	Operational gate explicitly records production_authorized=false; немає risk owner, SSP/ATO або підписаного рішення про прийняття ризику. Наслідок: Запуск без юридично та організаційно визначеного власника ризику.	Призначити system owner, data owner, security owner; створити authorization package і signed go/no-go.	Підписаний authorization decision, scope, residual-risk register і expiry date. Tools: NIST AI RMF; NIST RMF/SSP; threat-model workshop
GOV-002	P0 UNVERIFIED_BLOCKER	Немає use-case-specific AI risk profile	Є загальні assurance-документи, але немає операційного профілю Govern→Map→Measure→Manage для конкретного військового застосування. Наслідок: Ризики оцінюються без визначеного контексту, шкоди, користувачів і допустимої помилки.	Створити AI system card, context map, harm model, risk appetite, human-oversight policy.	Кожен risk має owner, metric, control, evidence і review cadence. Tools: NIST AI RMF / AIRC playbook
GOV-003	P0 UNVERIFIED_BLOCKER	Немає затвердженої класифікації та правил обробки даних	Реальний корпус 5 960 файлів у release відсутній; classification guide, marking rules і handling matrix не надані. Наслідок: Можливий незаконний або небезпечний витік обмеженої інформації.	Провести inventory, rights/classification review, labeling, compartment mapping, retention/declassification rules.	100% corpus objects мають owner, class, rights, retention, releasability і access policy. Tools: Data inventory; DLP; classification workshop; legal review
GOV-004	P0 UNVERIFIED_BLOCKER	Немає незалежного TEVV, pentest і red-team	Усі наявні докази створені самим репозиторієм; зовнішнього аудитора й blind tests немає. Наслідок: Self-confirming assurance: одна й та сама модель помилок у коді й тестах.	Незалежний code review, API/cloud pentest, AI/RAG red-team, corpus poisoning exercise.	Незалежний звіт без відкритих P0/P1 та з повторною перевіркою remediation. Tools: OWASP ASVS/API Top 10; OWASP GenAI; MITRE ATLAS; NIST Dioptra
GOV-005	P0 UNVERIFIED_BLOCKER	Немає офіційної моделі предметної відповідальності	Review separation перевіряє лише різні subject strings; кваліфікації, повноваження, конфлікти інтересів і підпис рішення відсутні. Наслідок: Неавторитетний reviewer може легалізувати неправильний документ.	Registry reviewers/approvers, credential verification, COI policy, dual control, signed decisions.	Кожне approval криптографічно прив'язане до уповноваженої ролі та scope. Tools: PKI/e-sign; reviewer registry; workflow engine
GOV-006	P0 CONDITIONAL_RISK	Права на індексацію, OCR, цитування й передачу документів не доведені	Source hash доводить байти, але не license, copyright, distribution authority або право надсилати текст зовнішньому embedding provider. Наслідок: Юридичне блокування продукту та disclosure третім сторонам.	Провести rights clearance; заборонити external egress для неочищених класів.	Для кожного джерела зафіксовані дозволені операції та заборони. Tools: Legal/IP review; data-processing agreements
IAM-001	P0 VERIFIED_DEFECT	Небезпечний secure-by-default: dev auth дає restricted admin	Settings defaults: environment=local, auth_mode=dev, subject local-admin, усі привілейовані ролі, clearance=restricted. Наслідок: Помилка deployment-конфігурації запускає систему з повним самопризначеним доступом.	Заборонити dev auth у packaged runtime; вимагати explicit DEV_MODE acknowledgment і loopback-only binding.	Будь-який non-test start без OIDC/explicit local override завершується exit!=0. Tools: Pydantic discriminated settings; policy-as-code; negative startup tests
IAM-002	P0 VERIFIED_DEFECT	Production web-клієнт не реалізує OIDC	public/app.js викликає /v1/answers без Authorization; UI працює лише з dev auth або зовнішньою ручною	Реалізувати Authorization Code + PKCE, secure token handling/BFF, logout, expiry/refresh/error states.	End-to-end OIDC login/logout/expiry/revocation проходить у staging.

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
			ін'єкцією токена. Наслідок: Користувач не може безпечно автентифікуватися в production.		Tools: OIDC conformance suite; Playwright; BFF pattern
IAM-003	P0 VERIFIED_DEFECT	Привілеї напряму довіряються довільним OIDC claims	_identity_from_claims напряму приймає roles, clearance, corpora з токена без server-side entitlement map. Наслідок: Помилка IdP/client mapping може видати admin/restricted доступ.	Ввести PDP/entitlement registry; allowlist claims; audience/client-specific mapping; deny unknown.	Піддроблені/невідомі claims не підвищують доступ; mapping version audited. Tools: OPA/Cedar або власний PDP; contract tests
IAM-004	P0 CONDITIONAL_RISK	Модель доступу не виражає need-to-know/compartments	AccessTier і Classification мають лише кілька рівнів; немає compartments, releasability, purpose, unit/mission, device posture. Наслідок: Користувач із формальним рівнем може бачити нерелевантний обмежений корпус.	Розширити ABAC: compartments/caveats, purpose-of-use, affiliation, device trust, temporal/location policy.	Набір cross-compartment noninterference tests PASS на DB і API. Tools: OPA/Cedar; policy decision logs; model checking
IAM-005	P1 VERIFIED_DEFECT	OIDC assurance неповний	Verifier не вимагає acr/amr, azp, typ, jti; OIDC path не вимагає nbfi; немає revocation/replay cache. Наслідок: Використання слабкої автентифікації, replay або токена не того client context.	Вимарати phishing-resistant MFA assurance, typ/azp, jti replay policy, revocation/CAE за можливості.	Негативні тести для stale/replayed/wrong-client/low-assurance tokens PASS. Tools: OIDC conformance; token replay tests
IAM-006	P1 VERIFIED_DEFECT	RLS залежить від session GUC, який встановлює застосунок	PostgreSQL policy context задається set_config з identity від API. Компрометований app role/process може спробувати встановити ширший context. Наслідок: RLS захищає від помилки query, але не від app compromise/SQL execution.	Винести authorization у signed session context або окремі DB roles; заборонити прямий SQL; перевірити role privileges.	App role не може самостійно розширити effective claims навіть через довільний SQL. Tools: PostgreSQL RLS tests; pgaudit; signed context
IAM-007	P1 UNVERIFIED_BLOCKER	Немає lifecycle entitlement/offboarding	Не надано SCIM/HR source, deprovisioning SLA, periodic access review або stale-account tests. Наслідок: Звільнений/переведений користувач зберігає доступ.	SCIM/IdP lifecycle, quarterly recertification, emergency revoke.	Disable/revoke propagation виміряна та відповідає SLA. Tools: SCIM, IdP logs, access review
IAM-008	P1 UNVERIFIED_BLOCKER	Немає PAM/break-glass control	Admin роль існує, але немає just-in-time elevation, approval, session recording, emergency credentials. Наслідок: Постійний надмірний привілей і невідтворювані адміністративні дії.	JIT/PAM, two-person approval, break-glass runbook, immutable session logs.	Yci privileged sessions attributable, time-bounded і reviewed. Tools: PAM/Vault; SIEM
ING-001	P0 VERIFIED_DEFECT	Upload повністю буферизується в RAM	_read_upload_limited збирає list[bytes] і b"".join до 50 MB; concurrent ingestions множать memory pressure. Наслідок: Memory exhaustion/DoS і подвійне копіювання payload.	Stream у quarantine object/file із incremental hash і hard quota; не зберігати повний bytes у RAM.	Peak RSS bounded під N concurrent max-size uploads. Tools: Streaming multipart; tempfile/object store; load tests
ING-002	P0 VERIFIED_DEFECT	OCR/парсинг синхронні в API request	Ingestion виконує PdfReader, pdftoppm і tesseract у threadpool до відповіді; немає durable job state. Наслідок: Timeout, втрата роботи при restart, starvation API workers.	Durable queue/workflow, idempotency key, resumable states, cancellation, retry/dead-letter.	Crash/restart test завершує або безпечно повторює job без дублювання. Tools: Temporal/Celery/Arq; Postgres job ledger
ING-003	P0 VERIFIED_DEFECT	Немає malware scan/CDR до parser execution	У pipeline немає AV, YARA, CDR або quarantine decision перед rypdf/poppler/tesseract. Наслідок: Шкідливий документ атакує parser/toolchain.	Quarantine service: magic sniffing, AV/YARA, CDR, parser sandbox; лише clean artifact далі.	EICAR/malformed/polyglot fixtures блокуються до extraction. Tools: ClamAV/YARA; CDR; sandboxed worker
ING-004	P0 VERIFIED_DEFECT	Untrusted PDF парситься в API trust domain	rypdf працює in-process; poppler/tesseract запускаються у тому ж container namespace. Наслідок: Parser RCE/DoS отримує	Винести extraction у disposable no-network sandbox з seccomp/AppArmor, read-only FS, uid, cgroup quotas.	Compromise simulation не бачить DB/IdP/S3 credentials і не має egress. Tools: gVisor/Firecracker/Kubernetes sandbox; seccomp

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
ING-005	P0 VERIFIED_DEFECT	Aggregate OCR budget фактично не обмежений	доступ до API secrets/DB/network. 300 s timeout застосовується pdftoppm і окремо кожному tesseract page; до 500 pages. Наслідок: Один документ може зайняти години CPU та блокувати ingestion slots.	Global wall-clock/CPU/pixel budget; per-page deadline; max rendered pixels; early abort.	Worst-case file завершується в заданий budget і очищає temp artifacts. Tools: cgroups; process supervisor; timeout budget tests
ING-006	P1 VERIFIED_DEFECT	File-type validation обмежена extension/MIME/PDF magic	Для txt/json/html немає libmagic/content sniffing; PDF перевіряє лише %PDF-. Наслідок: Polyglot/mislabeled content проходить до parser.	libmagic + parser-specific structural validation; reject ambiguity.	Mismatch/polyglot suite fail-closed. Tools: python-magic/libmagic; corpus of polyglots
ING-007	P1 VERIFIED_DEFECT	Regex-based HTML stripping не є безпечним parser	_strip.html використовує regex і втрачає структуру/може некоректно обробляти malformed HTML. Наслідок: Прихований/злитий текст, помилкові цитати, resource abuse.	Parser HTML allowlist, DOM text extraction, limits на depth/nodes.	Malformed HTML corpus не змінює смислові межі непередбачувано. Tools: lxml/html5lib sandbox; fuzzing
ING-008	P1 VERIFIED_DEFECT	Object store write не атомарний із metadata transaction	object_store.put виконується до create_*_bundle; rollback БД залишає orphan object. Наслідок: Накопичення неврахованих даних і retention/privacy drift.	Staging key + transactional outbox/commit marker + orphan reconciler/GC.	Injected DB failure не лише доступно orphan або GC видаляє його за SLA. Tools: Saga/outbox; inventory reconciliation
ING-009	P1 VERIFIED_DEFECT	Немає OCR/layout quality model	Зберігається текст і page, але немає confidence, bounding boxes, table/list structure, reading order quality. Наслідок: Цитата може бути формально прив'язана до хибного OCR.	Layout-aware extraction, OCR confidence, low-confidence quarantine, visual review UI.	CER/WER/table extraction виміряні по stratified corpus; low confidence не auto-approve. Tools: Document AI/layoutparser; OCR benchmarks
ING-010	P1 VERIFIED_DEFECT	Автентичність джерела не перевіряється	source_uri/issuer — metadata; немає digital signature, official registry reconciliation, TLS capture або trusted timestamp. Наслідок: Hash доводить лише отримані байти, не офіційність документа.	Source connectors з domain allowlist, signature verification, publication ID reconciliation.	Authority status виникає лише після криптографічної/реєстрової перевірки або human attestation. Tools: PKI/PAdES; registry API; timestamp service
ING-011	P1 VERIFIED_DEFECT	Deduplication лише exact SHA-256	OCR/reformat/scan copies одного документа мають різні hashes. Наслідок: Конфліктні дублікати, перекіс retrieval, зайва review-робота.	Near-duplicate detection: simhash/minhash/layout/OCR fingerprint; canonical merge workflow.	Known duplicate families об'єднуються з precision/recall gate. Tools: datasketch; perceptual hash
ING-012	P1 UNVERIFIED_BLOCKER	Немає corpus-scale ingestion recovery drill	Немає доказу повторного імпорту тисяч файлів, resume, checkpoints, quarantine backlog і throughput. Наслідок: Масова міграція може зависнути або дати частковий корпус.	Run full-scale replay with injected failures and deterministic reconciliation.	100% source manifest reconciled; no missing/duplicate versions. Tools: Workflow engine; fault injection; load generator
RAG-001	P0 VERIFIED_DEFECT	Evaluation dataset є synthetic fixture, не production evidence	EVAL_REPORT: 30/30, calibration_status=UNVALIDATED_TEST_FIXTURE. Наслідок: Високий pass rate не прогнозує реальну точність на українському корпусі.	Створити frozen stratified gold set із реальних документів і adversarial holdout.	Blind holdout, human adjudication, versioned dataset, confidence intervals. Tools: Annotation platform; HELM-style scenario matrix; RAGChecker/ALCE metrics
RAG-002	P0 VERIFIED_DEFECT	Calibration profile не криптографічно зв'язаний з фактичним dataset artifact	Profile містить dataset_sha256, але Settings.load не звіряє hash з конкретним dataset file і не перевіряє signature/approver. Наслідок: Можна подати profile із вигаданими метриками/хешем.	Signed calibration bundle: dataset, labels, code digest, metrics, profile, approvers.	Runtime перевіряє signed bundle та точний dataset/code digest перед calibrated mode. Tools: in-toto/LSA attestation; cosign; reproducible eval
RAG-003	P0 UNVERIFIED_BLOCKER	Немає human gold standard та inter-annotator agreement	В release немає domain experts, adjudication protocol, Cohen/Fleiss kappa або disagreement set. Наслідок: Невідомо, чи ground truth взагалі стабільний і предметно	Подвійна незалежна розмітка, adjudication, reviewer qualifications, ambiguity labels.	IAA threshold predefined; ambiguous cases excluded/separately scored. Tools: Label Studio/Argilla; statistical analysis

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
RAG-004	P1 VERIFIED_DEFECT	Evidence support вимірюється token overlap, не entailment	правильний. sentence_candidates/query_coverage та support score не доводять, що citation логічно підтримує claim. Наслідок: Правдоподібна, але не підтверджена відповідь проходить gate.	Claim decomposition + NLI/attribution verifier + human spot checks; contradiction state.	Citation precision/completeness i entailment measured per claim, not query token overlap. Tools: NLI model/local verifier; ALCE; attribution benchmark
RAG-005	P1 VERIFIED_DEFECT	Немає contradiction resolution між джерелами	Pipeline ранжує фрагменти, але не виявляє взаємно суперечливі чинні норми/редакції. Наслідок: Система обирає одну відповідь при невирішеному конфлікті.	Conflict graph, issuer/jurisdiction precedence, explicit conflict abstention.	Known conflict cases повертають conflict status i всі релевантні sources. Tools: NLI contradiction; rule engine; temporal graph
RAG-006	P1 VERIFIED_DEFECT	Citation completeness метрика не відповідає claim coverage	evidence_coverage формується з query token coverage; не рахує всі factual claims. Наслідок: Відповідь може мати citation, але частина тверджень лишається без доказу.	Виділяти atomic claims i вимагати support для кожного; окремо correctness/completeness.	100% emitted claims мають verified supporting spans або answer abstains. Tools: ALCE/RAGChecker-style metrics
RAG-007	P1 VERIFIED_DEFECT	Authority priors є неперевіреними константами	OFFICIAL_UA=1.0, allied=.92, manufacturer=.78 тощо без empirical provenance. Наслідок: Скалярний prior може переважити релевантність i контекстну правову силу.	Контекстна authority policy: document type, issuer competence, jurisdiction, date, task.	Ablation i domain validation доводять користь; priors versioned and approved. Tools: Policy rules + calibration/ablation
RAG-008	P1 VERIFIED_DEFECT	Temporal score вимірює наявність metadata, не temporal relevance	_temporal_specificity=1.0 якщо effective_from існує, 0.6 для publication date. Наслідок: Старий документ отримує такий самий temporal bonus, як актуальний.	Temporal distance/applicability features; interval algebra; supersession graph.	As-of queries правильно ранжують/відсікають historical/current versions. Tools: Bitemporal DB tests; temporal benchmark
RAG-009	P1 VERIFIED_DEFECT	Risk classifier є regex heuristic	Query risk визначається невеликим набором pattern rules. Наслідок: Перефразування обходить stricter thresholds; false positives блокують корисні запити.	Train/evaluate transparent risk classifier або rule DSL з broad test corpus; fail-closed unknown.	Per-class precision/recall + worst-group metrics на blind set. Tools: Property/adversarial tests; confusion matrix
RAG-010	P1 VERIFIED_DEFECT	Prompt/control injection detector має лише п'ять regex patterns	contains_control_injection не покриває obfuscation, Unicode, multilingual, indirect instructions. Наслідок: Poisoned text може бути процитований/оброблений як evidence.	Treat corpus as data structurally; instruction isolation; detector ensemble; poisoning metadata.	Adversarial corpus suite із direct/indirect/obfuscated injection має defined outcomes. Tools: MITRE ATLAS cases; Unicode fuzzing; document taint labels
RAG-011	P1 VERIFIED_DEFECT	Sentence segmentation непридатна для складних нормативних документів	Regex [^.!?'\n]+ не зберігає списки, таблиці, abbreviations, article/subclause hierarchy. Наслідок: Citation offsets i atomic claims можуть бути семантично неправильні.	Structure-aware parser: headings, clauses, bullets, tables, references; immutable offsets.	Gold structural extraction benchmark PASS per document class. Tools: PDF layout parser; Ukrainian sentence tokenizer
RAG-012	P1 VERIFIED_DEFECT	Lexical retrieval не має української морфології та domain analysis	Tokenizer лише casefold/regex/малий stoplist; немає lemmatization, synonyms, abbreviations. Наслідок: Recall падає через відмінки, військові скорочення, варіанти написання.	Ukrainian analyzer, controlled vocabulary, acronym expansion, query rewriting with audit.	Recall@20 та nDCG measured by query family, including morphology/acronyms. Tools: Stanza/UDPipe; domain thesaurus; BEIR-style evaluation
RAG-013	P1 UNVERIFIED_BLOCKER	Немає тестів таблиць, чисел, одиниць i формул	Eval fixtures переважно plain text; відсутні table-cell provenance i numeric consistency. Наслідок: Небезпечні помилки в дозах, строках, координатах, кількостях.	Table extraction, unit normalization, numeric entailment, exact-cell citation.	Numeric/table benchmark має zero critical unit/sign errors. Tools: Camelot/Docling/layout tools; unit tests

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
RAG-014	P1 UNVERIFIED_BLOCKER	Scale evidence не репрезентує production	SCALE_REPORT: 5 000 synthetic spans, SQLite FTS5, 80 iterations, one target query, no concurrency/network. Наслідок: Невідомі p95/p99, saturation, recall і cost на реальному corpus/Postgres.	Benchmark real corpus, concurrent mixed workload, cold/warm cache, failure cases.	SLO envelope with p50/p95/p99, throughput, recall, resource/cost curves. Tools: k6/Locust; pg_stat_statements; OpenTelemetry
RAG-015	P1 CONDITIONAL_RISK	Embedding integration може створити data egress	HttpEmbeddingProvider надсилає query/span text зовнішньому endpoint; data-class policy не enforced у provider interface. Наслідок: Restricted content залишає trust boundary.	Per-class provider policy, local models for restricted tiers, egress proxy/DLP, contracts/retention.	Restricted test corpus ніколи не викликає external endpoint; network evidence confirms. Tools: DLP; egress gateway; local embedding service
RAG-016	P1 UNVERIFIED_BLOCKER	Немає доказу synchronization/model migration embeddings	Є upsert/search, але немає доведеного durable pipeline для backfill, stale vectors, dual-index migration й rollback. Наслідок: Semantic retrieval використовує неповний або змішаний index.	Embedding job ledger, text_hash/model version reconciliation, blue-green index migration.	100% approved spans have correct model/text hash before semantic weight activation. Tools: Queue; pgvector inventory; consistency checker
RAG-017	P1 UNVERIFIED_BLOCKER	Немає drift/online quality monitoring	Відсутні production labels, distribution shift, query slice dashboards, alerting on abstention/recall proxies. Наслідок: Якість деградує непомітно після corpus/model/query changes.	Shadow evaluation, sampled human review, drift metrics, rollback triggers.	Defined drift thresholds cause automatic freeze/rollback. Tools: Evidently/custom metrics; review queue
RAG-018	P1 UNVERIFIED_BLOCKER	Немає захисту від corpus/RAG poisoning як процесу	Є окремі injection fixtures, але немає source anomaly detection, reputation/authority compromise scenario, poisoned update drill. Наслідок: Авторитетно оформлений шкідливий документ впливає на відповіді.	Source provenance, anomaly detection, multi-review, canary corpus release, rollback.	Poisoned-source exercise detected before general release. Tools: MITRE ATLAS; content diff; signed releases
RAG-019	P2 VERIFIED_DEFECT	Score не є каліброваною ймовірністю, але UI подає його як метрику	Convex utility bounded [0,1] не має probabilistic interpretation. Наслідок: Користувач може сприймати 0.8 як 80% істини.	Rename to ranking utility; show calibrated risk/coverage separately; uncertainty UX.	UI/docs clearly distinguish utility, evidence coverage, error bound. Tools: Calibration plots; UX research
RAG-020	P2 VERIFIED_DEFECT	Малі мінімальні вибірки не гарантують domain coverage	minimum 100 ranking queries/200 accepted samples без stratification. Наслідок: Aggregate metric маскує провал рідкісних критичних сценаріїв.	Stratified sample-size plan per domain/risk; bootstrap confidence intervals; preregistered gates.	Each critical stratum meets minimum N and upper error bound. Tools: Power analysis; bootstrap
INF-001	P0 UNVERIFIED_BLOCKER	Docker/Compose runtime не був фактично виконаний у середовищі аудиту	Release report explicitly marks container execution as external GitLab gate. Наслідок: Compose може не піднятися або інтеграції можуть бути невірно wired.	Запустити clean host deployment, smoke/E2E, restart/upgrade/downgrade, network tests.	Full stack starts from zero and passes E2E under non-root roles. Tools: Docker/Podman; Testcontainers; GitLab runner
INF-002	P0 VERIFIED_DEFECT	docker-compose.yml є local topology, не production deployment	environment=local, auth=dev, HTTP MinIO/OTLP, localhost port; single instances. Наслідок: Неприпустимо використовувати manifest як production.	Створити окремі staging/prod IaC modules; видалити implicit promotion local compose.	Production config passes policy-as-code and has no dev settings/plain HTTP. Tools: Terraform/Pulumi; Helm/Kubernetes або hardened VMs
INF-003	P0 UNVERIFIED_BLOCKER	Немає production TLS ingress і service identity	Nginx слухає HTTP 8080; внутрішні S3/OTLP HTTP у local compose; production ingress manifest відсутній. Наслідок: MITM/credential exposure при неправильній мережевій межі.	TLS 1.2/1.3 ingress, mTLS/service mesh або equivalent, certificate rotation.	All external and sensitive internal paths cryptographically authenticated. Tools: cert-manager/Envoy/Nginx; TLS scanners
INF-004	P0 UNVERIFIED_BLOCKER	Немає HA/failover/PITR topology	Один PostgreSQL, MinIO, API, web; немає replica/failover/WAL archive/multi-zone proof. Наслідок: Single point of failure та втрата даних.	Define availability class; HA Postgres, object replication, redundant API, PITR.	Failover drill meets defined RTO/RPO with no authorization bypass. Tools: Patroni/managed Postgres; object replication; chaos test

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
INF-005	P0 UNVERIFIED_BLOCKER	Backup/restore не доведено на live production-like PostgreSQL	Локально тестуються crypto/fake binaries; live job існує в CI, але не виконаний у цьому аудиті. Наслідок: Ваксуп може бути невідновним у реальному середовищі.	Quarterly live restore to isolated environment, data validation, RLS/auth tests, timed RTO/RPO.	Independent restore evidence with measured RTO/RPO and checksum reconciliation. Tools: pg_dump/pg_restore or physical backup; restore automation
INF-006	P0 UNVERIFIED_BLOCKER	Немає production secret manager/KMS/HSM і rotation evidence	Local secrets — files; audit/backup keys in app runtime; rotation protocol не доведений. Наслідок: Компрометація host/app відкриває keys і audit forgery/decryption.	Vault/KMS/HSM, workload identity, envelope encryption, rotation/revocation drills.	No long-lived static secrets in images/files; rotation without downtime tested. Tools: HashiCorp Vault/cloud KMS/HSM
INF-007	P1 VERIFIED_DEFECT	API має загальний egress без destination allowlist	Compose egress network дає API зовнішній вихід; немає проху/policy by hostname/IP/data class. Наслідок: SSRF або compromised process exfiltrates corpus/secrets.	Default-deny egress gateway; allowlist OIDC/S3/anchor/embedding; DNS/TLS pinning where appropriate.	Unexpected destinations unreachable; egress logs attributable. Tools: NetworkPolicy/eBPF/proxy; SSRF tests
INF-008	P1 UNVERIFIED_BLOCKER	Resource limits не калібровані capacity plan	Compose CPU/memory/pids values є static; немає навантажувального provenance. Наслідок: OOM/throttling або зайве резервування.	Load/capacity model by workload; autoscaling/admission budgets; saturation alerts.	Limits derived from measured envelope and documented headroom. Tools: k6/Locust; cAdvisor; pg metrics
INF-009	P1 VERIFIED_DEFECT	OTel collector healthcheck перевіряє config, не serving path	Healthcheck запускає `otelcol validate`; не доводить, що receiver/exporter працює. Наслідок: Telemetry silently unavailable while container healthy.	Use health_check extension endpoint + synthetic trace/metric canary.	Dropped exporter/receiver causes readiness/alert according to policy. Tools: OpenTelemetry Collector healthcheck; synthetic probe
INF-010	P1 VERIFIED_DEFECT	Local audit anchor не є незалежним trust domain	Compose file anchor volume керується тим самим host/operator, що API/DB. Наслідок: Host compromise може змінити ledger і anchor.	Remote append-only witness in separate account/org; asymmetric signatures/trusted timestamp.	Single host/admin compromise cannot rewrite accepted history. Tools: Transparency log/Rekor-like service; HSM signing
INF-011	P1 UNVERIFIED_BLOCKER	Немає deployment rollback/canary/schema compatibility proof	CI build/package є, але нема staged rollout, backward-compatible migrations, rollback under live traffic. Наслідок: Нова версія може зробити DB/clients незворотно несумісними.	Expand-contract migrations, canary, automated rollback, compatibility tests.	N-1/N compatibility and rollback drill PASS. Tools: Argo Rollouts/GitLab environments; contract tests
INF-012	P1 UNVERIFIED_BLOCKER	Немає offsite/immutable backup schedule and retention execution	Scripts/manifest є; scheduler, remote immutable target, retention/deletion monitoring не надані. Наслідок: Ransomware/operator error знищує primary і backup.	3-2-1 backups, object lock, isolated credentials, restore cadence.	Backup age/immutability monitored; restore sampled automatically. Tools: Backup scheduler; WORM storage
SRE-001	P0 UNVERIFIED_BLOCKER	Немає SLO/SLI/error-budget contract	Немає визначених availability, latency, freshness, ingestion durability, answer quality SLO. Наслідок: Неможливо об'єктивно вирішити launch або regression.	Define user journeys, SLIs, SLOs, error budget, alert policy.	Approved SLO document and burn-rate alerts validated. Tools: Google SRE methods; Prometheus/OpenTelemetry
SRE-002	P0 UNVERIFIED_BLOCKER	Немає on-call ownership та incident exercises	Runbooks є, але немає roster, escalation, paging, game-day evidence, postmortems. Наслідок: Інцидент не буде вчасно виявлений/локалізований.	On-call model, severity matrix, paging, tabletop + technical game days.	Timed exercises meet detection/containment/recovery targets. Tools: PagerDuty/Opsgenie equivalent; incident tooling
SRE-003	P1 VERIFIED_DEFECT	Observability не має durable backend	OTel collector config у local topology фактично debug-oriented; нема metrics/logs/traces storage, dashboards, retention. Наслідок: Немає історичного аналізу, alerting і forensic evidence.	Deploy metrics/traces/logs backend, RED/USE dashboards, retention and access controls.	Synthetic failures visible end-to-end and page correct owner. Tools: Prometheus/Grafana/Loki/Tempo або managed stack
SRE-004	P1 UNVERIFIED_BLOCKER	Немає chaos/failure-injection matrix	Не доведені outages DB/S3/IdP/anchor/embedding/network/clock/disk-full. Наслідок: Невідомі cascading failures і	Fault injection per dependency, partial failures, latency, stale cache, clock skew.	Every dependency has defined degraded/fail-closed behavior and recovery evidence. Tools: Toxiproxy/Chaos Mesh; pytest

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
			ambiguous transaction outcomes.		integration
SRE-005	P1 UNVERIFIED_BLOCKER	Немає production load/concurrency endurance test	Local scale probe single query/SQLite; немає soak, ingestion+query mixed load, connection-pool saturation. Наслідок: Race, leaks, queue collapse, p99 spikes з'являться лише в експлуатації.	Mixed workload load/soak/spike tests; saturation and backpressure validation.	Meet SLO under target and overload sheds load without leakage/corruption. Tools: k6/Locust; pgbench; profiling
SRE-006	P1 CONDITIONAL_RISK	Readiness має невизначену degraded-mode policy	Critical dependency failure може зробити instance unready; немає формальної read-only/lexical-only policy by risk class. Наслідок: Зайва недоступність або небезпечний silent fallback.	Define dependency matrix: required/optional per environment/query risk; expose degraded state.	Each outage returns predeclared status; no silent semantic/policy downgrade. Tools: State machine; chaos tests
SRE-007	P1 UNVERIFIED_BLOCKER	Немає data/corpus release rollback drill	Supersession/cache release logic тестується локально, але немає mass release/canary/rollback operational procedure. Наслідок: Poisoned або хибний corpus release впливає на всіх.	Immutable corpus releases, canary cohort, shadow eval, atomic rollback.	Rollback restores prior answers/index within defined RTO. Tools: Release registry; feature flags
SUP-001	P0 VERIFIED_DEFECT	Container/CI images pinned tags, not immutable digests	CI/Compose/Dockerfile use version tags (python, pgvector, Trivy, Syft, MinIO, BuildKit). Наслідок: Tag re-publish changes build без source change.	Resolve and pin digest; automated verified update PRs; policy enforcement.	All release inputs are digest-pinned and provenance records exact digests. Tools: Renovate/Dependabot; cosign; registry policy
SUP-002	P0 VERIFIED_DEFECT	Python lock files не містять hashes	pip install використовує versions і --no-deps, але не --require-hashes. Наслідок: Compromised index/artifact може підмінити wheel/sdist.	Hash-pin all artifacts; private mirror; binary-only policy; provenance verification.	Offline/reproducible install succeeds only for approved hashes. Tools: pip-tools/uv lock; --require-hashes; artifact registry
SUP-003	P0 UNVERIFIED_BLOCKER	Немає signed build provenance і artifact signing	Є SHA-256/manifest, але нема hosted-builder attestation, cosign signature, transparency log. Наслідок: Неможливо довести, хто/як побудував production image.	Generate SLSA provenance, sign images/SBOM, verify before deploy.	Deployment admission rejects unsigned/unexpected provenance. Tools: GitLab OIDC + cosign/in-toto; SLSA verifier
SUP-004	P1 VERIFIED_DEFECT	BuildKit запускається з no-process-sandbox	CI sets BUILDKITD_FLAGS=--oci-worker-no-process-sandbox. Наслідок: Build steps мають слабку isolation boundary.	Use hardened hosted builder/runner or isolated VM; remove flag where feasible.	Malicious build step cannot inspect other jobs/host secrets. Tools: GitLab isolated runner; rootless BuildKit with sandbox
SUP-005	P1 UNVERIFIED_BLOCKER	Security scanners не були виконані в локальному аудиті	Ruff/мypy/pip-audit/Trivy/Gitleaks jobs визначені, але tool results не надані з real GitLab run. Наслідок: Current dependencies/config may contain known issues.	Run pipeline in isolated runner; archive signed reports; fix all policy violations.	Signed pipeline evidence, zero unaccepted high/critical findings. Tools: GitLab CI; Trivy; pip-audit; Gitleaks; Ruff; mypy
SUP-006	P1 VERIFIED_DEFECT	Static security analysis coverage incomplete	CI має Ruff/Trivy/Gitleaks/pip-audit, але нема Semgrep/Bandit/CodeQL-equivalent, DAST, parser fuzzing. Наслідок: Logic/security flaws не представлені dependency/config scans.	SAST rules, API DAST, fuzzing, IaC policies, secret history scan.	Security test matrix maps every threat class to executable gate. Tools: Semgrep/Bandit; Schemathesis/ZAP; Atheris
SUP-007	P1 UNVERIFIED_BLOCKER	GitLab branch/tag controls не доведені repository files	CODEOWNERS/CI exist, але protected branch, approval count, signed tags, runner isolation are server settings. Наслідок: Unilateral bypass або malicious runner може publish release.	Export GitLab settings evidence; 2-person review; protected tags; isolated runners.	No single contributor can alter protected release without independent approval. Tools: GitLab API/audit events; SLSA Source track
SUP-008	P1 UNVERIFIED_BLOCKER	Немає continuous re-scan/patch SLA та KEV policy	Одноразовий build scan не доводить стан через день після release. Наслідок: Нові CVE залишаються непоміченими.	Scheduled rescans, SBOM inventory, KEV SLA, emergency rebuild/revoke.	High/critical/KEV triage and remediation SLA measured. Tools: Dependency Track/Grype/Trivy; CISA KEV feed
SUP-009	P2 UNVERIFIED_BLOCKER	Немає license/compliance inventory	SBOM jobs є, але license policy/notice/forbidden licenses не зафіксовані. Наслідок: Юридичний ризик	License scan, approved license policy, notices.	Release має complete license report і zero forbidden components. Tools: Syft/ScanCode/FOSSA equivalent

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
COD-001	P1 VERIFIED_DEFECT	SqlRepository є infrastructure god object	distribution/deployment. repository.py ≈ 1 289 LOC, близько 46 functions; змішує schema, CRUD, search, audit, readiness, RLS context. Наслідок: Зростає change coupling і шанс неповного security fix.	Розділити repositories/UoW: documents, versions, search, audit, health; transactional boundaries explicit.	Кожен модуль має одну responsibility; security invariants tested across UoW. Tools: Architecture tests; dependency-cruiser equivalent
COD-002	P1 VERIFIED_DEFECT	Security config validator має надмірну цикломатичну складність	validate_security_and_calibration ≈ CC 56, багато взаємозалежних modes. Наслідок: Конфігураційні комбінації важко довести; тупо/новий mode може fail-open.	Typed environment profiles/discriminated unions; policy table; exhaustive config tests.	All valid/invalid profile combinations generated and checked. Tools: Pydantic models; property-based testing
COD-003	P1 VERIFIED_DEFECT	Broad `except Exception` у critical paths	Є у readiness/retrieval/extraction/semantic/object-store/anchor/resilience/routes. Наслідок: Пізні failure causes collapse; programming bugs маскуються як dependency failure.	Narrow exceptions, typed failure taxonomy, preserve cause, alert unexpected errors.	Unexpected exception propagates to crash/alert in test, not generic safe-looking state. Tools: Ruff BLE; error budget tests
COD-004	P1 VERIFIED_DEFECT	Branch coverage значно нижча за statement coverage	Measured: statements 86.72%, branches 64.78%, combined 82.34%. Наслідок: Happy-path statements маскують неперевірені decision branches.	Per-module branch thresholds for security-critical code; MC/DC-inspired cases.	Auth/policy/ingestion/audit branches ≥ 90% or justified exclusions. Tools: coverage.py branch; diff coverage
COD-005	P1 VERIFIED_DEFECT	Mutation score 100% стосується лише 14 hand-selected mutants	MUTATION_REPORT: 14/14; це не exhaustive mutation testing. Наслідок: Неперевірені предикати можуть бути слабкими попри 100%.	Run broad mutation engine by module; track equivalent mutants; risk-based mutation budget.	Mutation score reported over declared operator space, survivors triaged. Tools: mutmut/cosmic-ray/custom operators
COD-006	P1 UNVERIFIED_BLOCKER	Немає parser/API fuzzing	Немає Hypothesis/Atheris/libFuzzer corpus for PDF metadata, JSON, HTML, multipart, JWT, query syntax. Наслідок: Crash/DoS/input edge cases невідомі.	Coverage-guided fuzzing, property tests, regression corpus.	No crash/hang/leak in defined CPU-hour budget; all findings regression-tested. Tools: Atheris/Hypothesis; Schemathesis; OSS-Fuzz style
COD-007	P2 VERIFIED_DEFECT	мypy і Ruff policies слабкі для critical system	mypy ignore_missing_imports=true; Ruff selects limited rules. Наслідок: Integration types/security smells проходять непомічено.	Strict typing by module, stubs/protocols, broader Ruff/security rules.	Zero unexplained Any at trust boundaries; complexity budgets enforced. Tools: mypy strict/pyright; Ruff S/C90/BLE/ASYNC
COD-008	P2 VERIFIED_DEFECT	Web lint/typecheck є лише asset-existence validator	package scripts lint/typecheck обидва запускають validate.mjs; JS type semantics не перевіряються. Наслідок: UI auth/security regressions не ловляться.	TypeScript, ESLint, DOM/unit/E2E tests, CSP tests.	OIDC/error/accessibility flows covered; real typecheck compiles. Tools: TypeScript/ESLint/Vitest/Playwright
COD-009	P2 VERIFIED_DEFECT	Критичні модулі мають низьке покриття	cli 0%, semantic ≈ 40.7%, extraction ≈ 68%, auth ≈ 72%, OIDC ≈ 77%. Наслідок: Саме integration/security/error paths найменше перевірені.	Raise targeted branch/mutation/failure-mode coverage, not aggregate only.	Per-risk module gates pass and no aggregate masking. Tools: coverage/mutation/fault injection
COD-010	P2 UNVERIFIED_BLOCKER	Немає API compatibility/consumer contract suite	JSON schemas є частково, але немає OpenAPI diff, backward compatibility, generated-client tests. Наслідок: Release ламає UI/інтеграції непомітно.	OpenAPI freeze/diff, consumer-driven contracts, version/deprecation policy.	Breaking change requires major version and migration evidence. Tools: oasdiff/Schemathesis/Pact
WEB-001	P1 VERIFIED_DEFECT	UI покриває лише запит-відповідь	Немає production auth, ingestion, quarantine, review, approval, audit, corpus/version administration. Наслідок: Операційні процеси виконуються API/manual, що підвищує помилки й обходи.	Role-specific consoles with safe workflows, validation, reason codes, audit previews.	All critical workflows executable without raw DB/API manipulation. Tools: Typed web app; E2E role tests
WEB-002	P2 UNVERIFIED_BLOCKER	Немає accessibility/usability evidence	ARIA мінімальний; немає WCAG audit, keyboard/screen-reader tests, field error semantics.	WCAG 2.2 AA audit, keyboard/screen-reader, cognitive load tests.	Zero critical a11y defects; operational tasks pass usability tests. Tools: axe-core/Playwright; manual AT

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
			Наслідок: Частина користувачів не може надійно експлуатувати систему.		testing
AUD-001	P1 VERIFIED_DEFECT	Audit HMAC key доступний application process	Той самий процес генерує events і MAC. При full app compromise attacker може forge future history. Наслідок: Tamper evidence не захищає від повного compromise trust domain.	Asymmetric signing/HSM or external append-only log; split duties.	Application cannot mint valid historical witness alone. Tools: HSM/KMS; transparency log; trusted timestamp
AUD-002	P1 VERIFIED_DEFECT	Remote anchor protocol custom HTTP/HMAC	Немає стандартного transparency proof, asymmetric identity, external timestamp, multi-witness. Наслідок: Anchor service/operator compromise зменшує гарантії.	Use signed append-only log / independent witnesses; key rotation and inclusion proofs.	Offline verifier detects fork/truncation with independently trusted keys. Tools: Sigstore/Rekor-like; RFC3161 timestamp
AUD-003	P1 UNVERIFIED_BLOCKER	Key rotation/recovery ceremony не доведена	Немає live procedure for audit/backup/OIDC/service key rollover, compromise, re-encryption. Наслідок: Rotation може зламати verification або лишити compromised key valid.	Versioned key IDs, dual validation window, revocation, ceremony and drill.	Rotation and compromised-key drill preserve verifiability and availability. Tools: KMS/HSM; runbooks
AUD-004	P1 UNVERIFIED_BLOCKER	Немає SIEM export/correlation/retention	Audit chain локальна; durable security analytics and alert rules not demonstrated. Наслідок: Атаки виявляються запізно; forensic context розпорошений.	Structured signed audit export to SIEM; correlation with IdP/network/deploy logs.	Defined attack simulations trigger alerts with complete timeline. Tools: SIEM; OTel logs; pgaudit
DATA-001	P0 UNVERIFIED_BLOCKER	Немає enforceable retention/deletion/legal-hold policy	Object lock retention є config, але corpus-specific lifecycle, deletion, legal hold, declassification не реалізовані end-to-end. Наслідок: Незаконне довгоче зберігання або передчасне видалення доказів.	Lifecycle state machine per data class; legal hold; cryptographic erasure; audit.	Automated tests prove retain/delete/hold/declassify behavior. Tools: S3 lifecycle/KMS; policy engine
DATA-002	P1 UNVERIFIED_BLOCKER	Немає field-level privacy/minimization assessment	Документи можуть містити персональні/операційні дані; немає PII detection/redaction workflow. Наслідок: Sensitive data індексується/цитуються понад потребу.	PII/secret scanning, redaction versions, purpose limitation, disclosure review.	Known sensitive fixtures never appear in unauthorized retrieval/output/logs. Tools: DLP/NER; redaction tooling
DATA-003	P1 UNVERIFIED_BLOCKER	Немає immutable corpus release manifest підписаного data owner	Code release має manifest, але corpus release authority/signature/process не доведені. Наслідок: Неможливо довести точний набір документів, що породив відповідь.	Signed corpus manifest: object/version hashes, policies, calibration, approvals.	Every answer resolves to signed corpus release accepted by data owner. Tools: in-toto/cosign; corpus registry
DATA-004	P1 UNVERIFIED_BLOCKER	Немає continuous inventory/reconciliation object store  index	Orphans/stale vectors/missing objects можуть виникнути; formal reconciliation job не доведений. Наслідок: Silent incompleteness або data residue.	Scheduled bidirectional reconciliation with repair/quarantine and alerts.	Zero unexplained divergence; injected drift detected within SLA. Tools: Inventory jobs; checksums; pg queries
OPS-001	P2 UNVERIFIED_BLOCKER	Немає доказу reproducible container build	Source ZIP deterministic-ish, але container bit-for-bit rebuild або reproducibility variance не виміряні. Наслідок: Build environment може неявно змінювати artifact.	Rebuild on independent runner; compare digest; record allowed nondeterminism.	Two independent builds yield identical digest or explained signed variance. Tools: reproducible-build tooling; diffoscope
OPS-002	P2 VERIFIED_DEFECT	CI retry може приховувати flaky infrastructure behavior	default retry=1 for runner timeout/system failure; flakiness metrics absent. Наслідок: Нестабільність маскується повторним PASS.	Record retry count, fail on test retry, flake dashboard/quarantine policy.	Release has zero unexplained flaky tests over defined window. Tools: GitLab analytics; pytest-rerun only diagnostic
OPS-003	P2 UNVERIFIED_BLOCKER	Немає release evidence retention policy	GitLab package artifacts expire in 30 days; long-term audit archive not demonstrated.	Immutable long-term evidence registry with retention aligned to system lifetime.	Every production release evidence retrievable and verified years later. Tools: Artifact registry/WORM

ID	Sev/State	Finding	Evidence / impact	Required action	PASS / tools
			Наслідок: Пізніше неможливо відтворити evidence release.		
OPS-004	P2 UNVERIFIED_BLOCKER	Hemae environment drift detection	No evidence of desired-state vs live infrastructure reconciliation. Наслідок: Manual changes bypass reviewed configuration.	GitOps/IaC drift detection, admission policy, periodic attestation.	Unauthorized drift detected and reverted/blocked. Tools: Terraform plan/OPA/Kyverno/GitOps
OPS-005	P2 UNVERIFIED_BLOCKER	Hemae cost/capacity governance	API/OCR/embedding/storage costs and quotas are not modeled/alerted. Наслідок: Resource abuse або неконтрольована вартість.	Per-tenant quotas, cost attribution, budget alerts, rate policy.	Cost per ingest/query measured; budget breach triggers safe throttling. Tools: FinOps metrics; quota service

9. Blind spots: що цим актом не доведено

- Відсутність zero-day або невідомих parser/dependency vulnerabilities.
- Поведінка live PostgreSQL/pgvector, Docker, object storage, IdP, remote anchor, KMS і мережі.
- Якість на реальному українському корпусі, включно з OCR, таблицями, суперечностями та історичними редакціями.
- Захищеність GitLab instance, runner, registry та адміністративних налаштувань.
- Юридична правомірність корпусу та відповідність українським військовим/державним процедурам.
- Фізична безпека, insider threat, endpoint/device security та operational security користувачів.

10. Production acceptance act — обов'язковий verdict gate

Gate	Required evidence	Result v4.0.0
P0 register	0 open findings	FAIL / OPEN
P1 register	0 open unless signed residual-risk acceptance with expiry	FAIL / OPEN
Identity	OIDC+PDP+RLS noninterference independently PASS	FAIL / OPEN
Corpus	100% signed classified manifest + rights + reviewers	FAIL / OPEN
Evidence	Blind real-corpus holdout and claim-level attribution PASS	FAIL / OPEN
Security	Independent pentest/red-team PASS	FAIL / OPEN
Supply chain	Signed SLSA provenance/SBOM and digest-pinned inputs	FAIL / OPEN
Reliability	SLO/load/chaos/HA/live restore PASS	FAIL / OPEN
Operations	On-call/game-day/incident/SIEM PASS	FAIL / OPEN
Authorization	Signed, time-bounded production authorization	FAIL / OPEN

11. Standards and research basis

NIST AI RMF 1.0 + Generative AI Profile NIST-AI-600-1: Govern/Map/Measure/Manage, TEVV, human oversight, risk ownership — <https://www.nist.gov/itl/ai-risk-management-framework>

NIST SP 800-218 / SP 800-218A: Secure SDLC and AI-specific software development practices — <https://csrc.nist.gov/pubs/sp/800/218/final>

CISA Secure by Design: Secure defaults, no default credentials, manufacturer ownership — <https://www.cisa.gov/securebydesign>

OWASP GenAI / LLM Top 10 2025: Prompt injection, poisoning, disclosure, supply chain, DoS, overreliance — <https://genai.owasp.org/llm-top-10/>

MITRE ATLAS: AI threat techniques including RAG poisoning and prompt injection — <https://atlas.mitre.org/>

SLSA v1.2: Source/build provenance, hosted/hardened builds and two-party controls — <https://slsa.dev/spec/v1.2/>

Google SRE Production Readiness Review: Architecture, dependencies, monitoring, emergency response, capacity and change management — <https://sre.google/sre-book/evolving-sre-engagement-model/>

Stanford HELM: Transparent, reproducible, multidimensional scenario evaluation — <https://crfm.stanford.edu/helm/>

ALCE (EMNLP 2023): Citation correctness and completeness evaluation — <https://aclanthology.org/2023.emnlp-main.398/>

RAGChecker (2024): Fine-grained retrieval/generation diagnostic metrics — <https://arxiv.org/abs/2408.08067>

BEIR (NeurIPS 2021): Heterogeneous IR benchmark and robustness of retrieval methods — <https://proceedings.neurips.cc/paper/2021/hash/65b9eea6e1cc6bb9f0cd2a47751a186f-Abstract-round2.html>

12. Фінальний акт

EVAL-GATE: FAIL.

Дозволений режим зараз: engineering development та controlled pilot на синтетичних/відкритих даних без критичних рішень. Production, restricted military data та офіційні нормативні відповіді — заборонені до закриття всіх P0 і проходження PR-01...PR-10.

System owner	_____ / дата
Security owner	_____ / дата
Data owner	_____ / дата
Independent assessor	_____ / дата